PRAVEEN V 241901082

Exercise 13
Detect Web Application Vulnerabilities Using Various Security Tools

AIM

To detect vulnerabilities in a target web application using various security tools such as OWASP ZAP, Nikto, Burp Suite and SQLMap, and to compare the findings across the different tools.

PROCEDURE

a) Scanning Using OWASP ZAP

1. Start the target web application and note its URL.
2. Open OWASP ZAP and set the browser proxy to route through it (127.0.0.1:8080).
3. Load the target site through the proxy so it is added to the Sites tab.
4. Right-click the target site and select Attack → Active Scan, then start the scan.
5. Open the Alerts tab after completion and note the vulnerabilities found with their severity.

b) Scanning Using Nikto

1. Open a terminal in Kali Linux.
2. Run Nikto against the target web server:
   nikto -h <target-URL>
3. Note the server misconfigurations, outdated software, default files and missing security headers reported.

c) Scanning Using Burp Suite

1. Open Burp Suite and route browser traffic through its proxy.
2. Browse the application with Intercept on to populate the Site Map.
3. Right-click the target in Site Map and select Scan (Burp Suite Professional) or manually test parameters using Repeater/Intruder.
4. Note any vulnerabilities identified (SQL injection, XSS, broken authentication).

d) Scanning Using SQLMap

1. Identify a URL parameter suspected of SQL injection (e.g., from the application's search or login form).
2. Run SQLMap against the parameter:
   sqlmap -u "http://target-app/listproducts.php?cat=1" --batch
3. Note whether the parameter is found to be injectable and the database type identified.

e) Comparing Results

1. Tabulate the vulnerabilities reported by each tool.
2. Note overlapping findings (detected by multiple tools) and unique findings (detected by only one tool).

PRAVEEN V 241901082

OBSERVATION TABLE

S.No	Tool Used	Vulnerability Detected	Severity	Remarks
1	OWASP ZAP	Cross-Site Scripting (XSS)	High	Found in search parameter
2	OWASP ZAP	Missing Anti-CSRF Tokens	Medium	Found in login form
3	Nikto	Outdated server software	Medium	nginx version outdated
4	Nikto	Missing X-Frame-Options header	Low	Clickjacking risk
5	Burp Suite	SQL Injection	High	Found in login parameter
6	SQLMap	SQL Injection confirmed	High	Database: MySQL, injectable parameter: cat

OUTPUT

OWASP ZAP Alerts:

High: Cross-Site Scripting (XSS) - /search.php?test=

Medium: Missing Anti-CSRF Tokens - /login.php

Nikto output:

+ Server: nginx/1.19.0 (outdated)

+ The X-Frame-Options header is not defined

+ /admin/: Admin login page found

Burp Suite finding:

Parameter 'uname' in /login.php appears to be vulnerable to SQL Injection

Payload: ' OR '1'='1

SQLMap output:

Parameter: cat (GET)

Type: boolean-based blind

Title: AND boolean-based blind - WHERE or HAVING clause

Database: MySQL

back-end DBMS: MySQL 5.5

Comparison result:

SQL Injection: detected by both Burp Suite and SQLMap

XSS: detected only by OWASP ZAP

Missing headers: detected only by Nikto

RESULT

Thus, vulnerabilities in the target web application were successfully detected using various security tools — OWASP ZAP, Nikto, Burp Suite and SQLMap. The findings were compared across tools, revealing both overlapping and unique vulnerabilities identified by each.